

Device Provisioning Policy

The Grand Marina Hotel — Water Monitoring System

Document Version	1.0
Created By	[Kayla Colletti]
Date	[April 2026]
Approved By	[Leave blank — for client signature]

1. Scope and Purpose

This policy governs the provisioning, management, and decommissioning of HYDROLOGIC devices connected to The Grand Marina Hotel's water monitoring system.

Devices Covered

Device ID	Location	Certificate	Status
HYDROLOGIC-MainBuilding-001	Mechanical Room A	device-001.pem	Active
HYDROLOGIC-PoolSpa-002	Pool Pump House	device-002.pem	Active
HYDROLOGIC-Kitchen-003	Kitchen Mechanical	device-003.pem	Active
[Future devices as deployed]			

2. New Device Onboarding Process

Step 1: Device Registration

- Each device is assigned a unique Device ID
- Each device is registered in the systems inventory with its location
- Each device identity is prepared for certificate-based authentication (mTLS)

Step 2: Certificate Generation

- *A unique certificate and private key pair is generated for each device*
- *Certificates are issued by a trusted internal Certificate Authority*
- *The certificate includes the device ID to uniquely identify it during authentication*
- *Both the client and server certificates are used to support mTLS*

Step 3: Certificate Installation

- *The device certificate and private key are securely installed on the device*
- *The CA certificate is also installed so the device can verify the server*
- *Private keys are stored securely on the device and are never transmitted in plaintext*

Step 4: Connection Verification

- *The device initiates a connection to the MQTT broker over TLS*
- *mTLS is verified by- the server the device certificate, and the device verifies the server certificate.*
- *Confirm successful connection with no TLS errors*
- *Verify the device can securely publish telemetry data*
- *Check broker logs to confirm authenticated device identity*

Step 5: Documentation

- *Record device ID, certificate details, provisioning date, and location*
- *Log successful mTLS authentication and connection status*
- *Maintain updated inventory of all provisioned devices*

Estimated time for full onboarding: around 30 minutes to 1 hour

3. Certificate Rotation Schedule

Current certificate validity period: 1 year (days/months/years)

Rotation Schedule:

- Automatic rotation every 12 months
- Manual rotation triggered by: suspected compromise, device replacement, or security incident
- Rotation before expiration with 30 days warning

Rotation Procedure:

1. Generate a new certificate and private key for the device using the internal CA.
2. Securely install the new certificate on the device prior to the old one expires
3. Restart or reconnect the device to the MQTT broker to validate the new certificate
4. Always revoke and remove the old certificate from the system.

Who is responsible:

Security engineer

4. Compromised Device Procedure

If a device is suspected to be compromised:

IMMEDIATE ACTIONS (within 15 minutes):

1. Kill the certificate: manually add the device certificate to the Certificate REvocation List and force an immediate sync with the MQTT broker to block handshake.
2. Kill the active TCP connection on the broker to boot the rogue device off the network instantly.
3. Flag the Device ID in the firewall to drop all traffic from its assigned IP/MAC addresses so it cannot sniff around the local network.

INVESTIGATION (within 24 hours):

1. Trace the payload: audit the broker logs and the database to see exactly what kind of data was published and if any command-and-control messages were sent.
2. Look at the hardware: pull the device from the field and check for physical tampering, by looking for serial port headers, shorted pins, or broken anti-tamper stickers.

RECOVERY:

1. Wipe the flash memory and push a fresh, verified firmware image over a secure wire.
2. Generate new private key's and cert's, and ensure that the old identities stay gone.

Emergency contact: Security Ops Center (SOC) Ext. 9110,
soc-alerts@grandmarina.com

5. Decommissioning Process

When a device is removed from service:

Step 1: Revoke Certificate

- *Invalidate the cert at the CA level. If the device tries to reconnect, the mTLS handshake should fail immediately since the serial number is now not accepted.*

Step 2: Remove from Monitoring

- *Delete the device from the Hydrologic dashboard and purge its unique topic tree from the broker's ACLs so the data stream goes dead.*

Step 3: Physical Removal

- *The device will get fully wiped of all local keys cryptographically. If its hardware then it will get shredded.*

Step 4: Documentation

- *Update the asset inventory to "Decommissioned" and archive the final log report and link the ticket number to why it was pulled.*

6. Policy Review

This policy will be reviewed:

- Annually
- After any security incident
- When new devices are added
- Other: Major MQTT broker version upgrades or CA migrations

Next review date: April 2027

Signatures

Role	Signature	Date
Prepared by: [Your Name]	Kayla Colletti	April 2026
Reviewed by: Maya Chen, Senior Security Engineer		
Approved by: Marcus Webb, General Manager, The Grand Marina Hotel		